

	INFORME PENTEST SOFTWARE **** (WEB)	FECHA DE ELABORACIÓN	Julio /2026
--	--	---------------------------------	----------------

Vulnerabilidad de Control de Acceso (IDOR) en la Función de Actualización de Datos del Perfil

Introducción

Durante la auditoría, realizada con autorización del desarrollador, se analizaron las solicitudes HTTP utilizadas para modificar la información de los perfiles de los clientes. En este proceso se identificó una vulnerabilidad de tipo Insecure Direct Object Reference (IDOR) en una solicitud HTTP **PUT**.

La vulnerabilidad se producía debido a que el servidor no verificaba correctamente que el usuario autenticado tuviera autorización para modificar el recurso especificado en la solicitud. Al modificar determinados identificadores y parámetros de la petición, fue posible alterar información perteneciente a otros perfiles.

Entre los datos que podían ser modificados se encontraban la foto de perfil, el nombre del usuario y la información asociada a la placa del vehículo.

Adicionalmente, el campo destinado a almacenar información relacionada con la placa permitía introducir una descripción considerablemente extensa. Esta característica podría ser abusada para introducir contenido no autorizado o información con fines maliciosos, especialmente si dicho contenido es posteriormente mostrado al propietario del vehículo u otros usuarios.

¿Qué es un IDOR?

Insecure Direct Object Reference (IDOR) es una vulnerabilidad que ocurre cuando una aplicación utiliza identificadores proporcionados por el cliente para acceder o modificar recursos, pero no implementa controles de autorización adecuados para comprobar que el usuario tiene permiso sobre el recurso solicitado.

	INFORME PENTEST SOFTWARE **** (WEB)	FECHA DE ELABORACIÓN	Julio /2026
--	--	---------------------------------	----------------

En este caso, la aplicación permitía realizar modificaciones sobre información asociada a perfiles de otros usuarios mediante una solicitud **PUT**, sin validar correctamente la relación entre el usuario autenticado y el recurso que estaba intentando modificar.

El problema no se encontraba únicamente en que los identificadores fueran modificables, sino en la ausencia de una validación de autorización del lado del servidor.

Más información en: [CWE-639: Authorization Bypass Through User-Controlled Key | MITRE](#)

Impacto

Una explotación exitosa de esta vulnerabilidad podría permitir a un usuario autenticado modificar información perteneciente a otros clientes sin autorización.

Entre las acciones identificadas se encontraban:

- Modificar la foto de perfil de otro usuario.
- Modificar el nombre asociado a otro perfil.
- Alterar la información relacionada con la placa de un vehículo.
- Introducir contenido arbitrario en el campo de descripción asociado a la placa.
- Manipular información que posteriormente podría ser visualizada por el propietario del perfil.
- Utilizar el campo de descripción para introducir contenido malicioso o información destinada a intimidar, engañar o extorsionar al propietario del vehículo.
- Alterar la integridad de la información almacenada en los perfiles de otros clientes.

El impacto principal corresponde a una violación de control de acceso y de la integridad de los datos. Aunque la aplicación se encontraba en una etapa temprana de desarrollo, la vulnerabilidad podría adquirir mayor impacto a medida que aumentara el número de usuarios y vehículos registrados.

Riesgo potencial

Desde la perspectiva de un atacante, la posibilidad de modificar información perteneciente a otros clientes podría utilizarse para realizar ataques dirigidos contra usuarios específicos.

Por ejemplo, un atacante podría modificar información visible dentro del perfil de un vehículo para introducir mensajes no autorizados o contenido diseñado para engañar, intimidar o presionar al propietario.

	INFORME PENTEST SOFTWARE **** (WEB)	FECHA DE ELABORACIÓN	Julio /2026
--	--	---------------------------------	----------------

Propuesta de Solución

Se recomienda implementar controles de autorización del lado del servidor para verificar que el usuario autenticado tenga permisos sobre el perfil que intenta modificar antes de procesar cualquier solicitud de actualización.

La aplicación no debería confiar únicamente en los identificadores proporcionados por el cliente. Antes de ejecutar la operación **PUT**, el servidor debe comprobar que el recurso solicitado pertenece al usuario autenticado o que este cuenta explícitamente con los permisos necesarios para modificarlo.

Como medida adicional, se recomienda:

- Validar la identidad del usuario autenticado antes de procesar la actualización.
- Comprobar la propiedad o autorización del recurso asociado al identificador recibido.
- Rechazar la solicitud cuando el usuario no tenga permisos sobre el perfil solicitado.
- Evitar confiar en identificadores enviados directamente por el cliente como mecanismo de autorización.
- Implementar controles de autorización para cada operación de lectura y modificación de recursos.
- Validar la longitud y el contenido de los campos de texto para evitar el almacenamiento de información excesiva o contenido no autorizado.
- Registrar y monitorear intentos de modificación de recursos pertenecientes a otros usuarios.

El control de acceso debe aplicarse en el servidor, independientemente de las validaciones implementadas en el frontend, ya que cualquier usuario puede modificar manualmente las solicitudes HTTP antes de enviarlas.